INFORME DE SEGURIDAD

Reporte técnico de hardening

Portal de clientes · portal-clientes.nexo.local

35.71%
CUMPLIMIENTO DEL PERFIL

Organización	Nexo Seguros
Servidor	Portal de clientes (portal-clientes.nexo.local / 10.20.10.15)
Sistema operativo	ubuntu 22.04
Entorno	production
Auditoría	0d0578dd-6574-4096-8222-e1225f502015
Perfil	Línea base CIS Ubuntu 22.04 · CIS Ubuntu Linux 22.04 LTS Benchmark v1.0.0
Fecha de ejecución	2026-10-29 17:58 UTC
Generado por	Valeria Ríos
Naturaleza	DATOS SIMULADOS DE PRUEBAS

Este documento presenta resultados técnicos de una evaluación autorizada. No es una certificación oficial de CIS. Los comandos sugeridos por IA, si aparecen, fueron revisados por una persona y no se ejecutan desde la plataforma.

ATENCIÓN: esta ejecución utilizó el conector simulado. Los resultados NO provienen de infraestructura real y se presentan únicamente como ejemplo de funcionamiento.

1. Resumen de resultados

	Valor
Cumplimiento	35.71%
Controles aplicables evaluados	14
Aprobados	5
Incumplidos	9
No aplicables	0
No evaluados	0
Cobertura de evaluación	100.00%
Hallazgos activos	9

Fórmula: aprobados / (aprobados + incumplidos) × 100. Los controles no aplicables y no evaluados se excluyen del denominador y se informan por separado.

2. Resultados por control

Aleatorización del espacio de direcciones (ASLR)	1.5.1	Media	APROBADO	kernel.randomize_va_space = 2 (esperado 2).
auditd habilitado y activo	4.1.1.2	Media	INCUMPLIDO	auditd instalado=False, activo=False, habilitado=False.
Bloqueo de cuentas por intentos fallidos	5.4.2	Alta	INCUMPLIDO	pam_faillock ausente; deny=no definido; unlock_time=no definido.
Requisitos de complejidad de contraseñas	5.4.1	Alta	INCUMPLIDO	minlen = 8 (mínimo 14); pam_pwquality presente.
Política por defecto del firewall: denegar entrada	3.5.1.7	Alta	INCUMPLIDO	Política entrante por defecto = accept.
Firewall UFW habilitado	3.5.1.3	Alta	APROBADO	UFW conf=yes, servicio=active, arranque=enabled.
Servicio de registro rsyslog habilitado	4.2.2.2	Media	APROBADO	rsyslog instalado=True, activo=True, habilitado=True.
Servicios de red innecesarios deshabilitados	Interno	Media	INCUMPLIDO	Servicios habilitados: avahi-daemon.service, vsftpd.service
Permisos restrictivos sobre /etc/shadow	6.1.5	Alta	APROBADO	/etc/shadow modo 640, propietario root:shadow.
SSH rechaza contraseñas vacías	5.2.9	Alta	APROBADO	PermitEmptyPasswords = no
SSH prefiere autenticación por clave pública	Interno	Media	INCUMPLIDO	PasswordAuthentication = yes; PubkeyAuthentication = yes
SSH limita los intentos de autenticación	5.2.18	Media	INCUMPLIDO	MaxAuthTries = 6 (máximo 4)
Acceso SSH directo de root deshabilitado	5.2.7	Alta	INCUMPLIDO	PermitRootLogin = yes
Actualizaciones y parches de seguridad instalados	1.9	Alta	INCUMPLIDO	3 paquete(s) actualizables; máximo permitido 0.

3. Hallazgos activos

Alta	detected	Actualizaciones y parches de seguridad instalados	2026-11-28
Alta	detected	Acceso SSH directo de root deshabilitado	2026-11-28

Media	detected	SSH limita los intentos de autenticación	2026-12-28
Media	detected	SSH prefiere autenticación por clave pública	2026-12-28
Media	detected	Servicios de red innecesarios deshabilitados	2026-12-28
Alta	detected	Política por defecto del firewall: denegar entrada	2026-11-28
Alta	detected	Requisitos de complejidad de contraseñas	2026-11-28
Alta	detected	Bloqueo de cuentas por intentos fallidos	2026-11-28
Media	detected	auditd habilitado y activo	2026-12-28

4. Recomendaciones aprobadas por revisión humana

El servidor mantiene paquetes actualizables, incluidos parches de seguridad. Una vulnerabilidad conocida podría ser explotada hasta la próxima ventana de mantenimiento.

Riesgo: Exposición a vulnerabilidades públicas con exploit conocido y posible incumplimiento del ciclo de parcheo.

Recomendación: Programar una ventana de mantenimiento, aplicar actualizaciones y reiniciar únicamente si el kernel lo requiere. Validar servicios críticos después.

```
sudo apt update && sudo apt list --upgradable
```

Actualiza el índice y lista los paquetes pendientes sin instalar.

Los comandos son sugerencias revisadas; no fueron ejecutados por la plataforma.

5. Evidencia técnica de incumplimientos

AUDITD · auditd habilitado y activo

auditd instalado=False, activo=False, habilitado=False.

```
disabled inactive
```

AUTH-FAILLOCK · Bloqueo de cuentas por intentos fallidos

pam_faillock ausente; deny=no definido; unlock_time=no definido.

```
auth required pam_unix.so account required pam_unix.so
```

AUTH-PWQUALITY · Requisitos de complejidad de contraseñas

minlen = 8 (mínimo 14); pam_pwquality presente.

```
__PWCONF__=1 minlen = 8 minclass = 1 password requisite pam_pwquality.so retry=3
```

FW-DEFAULT · Política por defecto del firewall: denegar entrada

Política entrante por defecto = accept.

```
__UFW__=1 DEFAULT_INPUT_POLICY="ACCEPT" DEFAULT_FORWARD_POLICY="DROP"
```

SERVICES · Servicios de red innecesarios deshabilitados

Servicios habilitados: avahi-daemon.service, vsftpd.service

```
ssh.service enabled cron.service enabled avahi-daemon.service enabled vsftpd.service enabled
```

SSH-KEYONLY · SSH prefiere autenticación por clave pública

PasswordAuthentication = yes; PubkeyAuthentication = yes

```
__SSHD__=1 passwordauthentication yes pubkeyauthentication yes
```

SSH-MAXAUTH · SSH limita los intentos de autenticación

MaxAuthTries = 6 (máximo 4)

```
__SSHD__=1 maxauthtries 6
```

SSH-ROOT · Acceso SSH directo de root deshabilitado

PermitRootLogin = yes

```
__SSHD__=1 permitrootlogin yes
```

UPDATES · Actualizaciones y parches de seguridad instalados

3 paquete(s) actualizables; máximo permitido 0.

```
__PENDING__=3
```

Limitaciones de la evaluación

- Este reporte evalúa únicamente los controles incluidos en el perfil y no constituye una certificación CIS.
- Una configuración conforme no garantiza la ausencia de vulnerabilidades ni de otros riesgos.
- Las comprobaciones son de solo lectura y no modifican la configuración del servidor.
- Los controles marcados como internos no son un mapeo oficial de CIS.
- La evidencia puede haber sido truncada por límites de tamaño; la evidencia completa está disponible en la plataforma.

Documento generado automáticamente por CIS Hardening Auditor. No contiene contraseñas, claves privadas ni tokens.